ISO 27001

Seguridad de la Información – ISO 27001

Política de Seguridad de la Información en la Nube

Esteban Chamblat Rojas

ESTEBAN CHAMBLAT

TABLA DE CONTENIDO

1. **OBJETIVO** 1
2. **ALCANCE** 1
3. **DIRECTRICES DE ORGANIZACIÓN 2**

- **3.1 Políticas para la Seguridad de la Información**
- **3.2 Roles y Responsabilidades en Seguridad**
- **3.3 Segregación de Tareas**
- **3.4 Responsabilidades de la Dirección**
- **3.5 Contacto con Autoridades y Grupos de Interés**
- **3.6 Seguridad de la Información en la Gestión de Proyectos**
- **3.7 Inventario de Activos y Uso Admisible**
- **3.8 Devolución de Activos**
- **3.9 Clasificación y Etiquetado de la Información**
- **3.10 Gestión de Medios Removibles**
- **3.11 Eliminación de Medios de Almacenamiento**
- **3.12 Control de Acceso y Gestión de Identidades**
- **3.13 Seguridad en la Relación con Proveedores**
- **3.14 Gestión de Incidentes de Seguridad**
- **3.15 Continuidad de Negocio y Recuperación ante Desastres**
- **3.16 Cumplimiento Legal y Normativo**

CLASIFICACIÓN: USO INTERNO | COPIA CONTROLADA *Documento propiedad de Pepito paga doble. Prohibida su reproducción total o parcial sin autorización.*

Seguridad de la Información – ISO 27001

Información del Documento	Detalle
Autor del Documento	Esteban Chamblat
Fecha de Creación	14/01/2025
Clasificación	Uso Interno / Confidencial

HISTORIA DE CAMBIOS DE VERSIÓN DEL DOCUMENTO

Versión	Fecha	Autor	Descripción
1.0	14-01-2025	Esteban Chamblat	Creación de documento
1.0.1	08-03-2025	Esteban Chamblat	Creación de documento

1. OBJETIVO

Establecer el marco organizativo de seguridad de la información para **Pepito paga doble**, definiendo las responsabilidades y los controles administrativos necesarios para proteger la infraestructura crítica, incluyendo los servicios de virtualización en **Proxmox VE**, el orquestador **Docker Swarm** y los sistemas de bases de datos **PostgreSQL**.

2. ALCANCE

CLASIFICACIÓN: USO INTERNO | COPIA CONTROLADA *Documento propiedad de Pepito paga doble. Prohibida su reproducción total o parcial sin autorización.*

Esta política es de cumplimiento obligatorio para toda la estructura organizacional de **Pepito paga doble**, afectando la gestión de servidores **Rocky Linux**, la administración de reglas de red en **pfSense** y los procesos de respaldo en **Veritas NetBackup**.

3. DIRECTRICES DE ORGANIZACIÓN

3.1 Políticas para la Seguridad de la Información

Las políticas de seguridad deben ser revisadas anualmente por Esteban Chamblat. Se realizarán ajustes cada vez que existan cambios significativos en la infraestructura de Rocky Linux o en los servicios de middleware OpenTux.

3.2 Roles y Responsabilidades en Seguridad

Cada colaborador es responsable de los activos asignados. Las funciones críticas de administración sobre el clúster de contenedores y los sistemas de resolución PowerDNS están limitadas a perfiles técnicos específicos.

3.3 Segregación de Tareas

Se prohíbe que una misma persona gestione la creación de usuarios y la auditoría de los mismos. El administrador de Veritas NetBackup no debe ser el único responsable de validar la integridad de las copias.

3.4 Responsabilidades de la Dirección

La dirección debe aprobar los recursos para el mantenimiento de la infraestructura y participar activamente en la revisión de los incidentes críticos reportados.

3.5 Contacto con Autoridades y Grupos de Interés

Esteban Chamblat mantendrá contacto con entidades de ciberseguridad y proveedores de tecnología para anticipar amenazas que afecten la conectividad SQLNet o la estabilidad de los servicios.

3.6 Seguridad en la Gestión de Proyectos

Todo nuevo despliegue en Docker Swarm o migración de bases de datos PostgreSQL debe pasar por una fase de evaluación de riesgos de seguridad previa.

3.7 Inventario de Activos y Uso Admisible

CLASIFICACIÓN: USO INTERNO | COPIA CONTROLADA *Documento propiedad de Pepito paga doble. Prohibida su reproducción total o parcial sin autorización.*

Se mantendrá un registro detallado de hardware y licencias. Los equipos deben usarse exclusivamente para fines laborales, evitando la instalación de software no autorizado que comprometa la red.

3.8 Devolución de Activos

Al finalizar el contrato, el colaborador debe entregar dispositivos y accesos. Se procederá al borrado inmediato de perfiles en los servidores de autenticación.

3.9 Clasificación y Etiquetado de la Información

La información se clasificará en: Pública, Uso Interno y Confidencial. Los documentos técnicos de infraestructura se consideran estrictamente Confidenciales.

3.10 Gestión de Medios Removibles

El uso de unidades USB o discos externos está restringido y sujeto a cifrado obligatorio para evitar fugas de datos de clientes o configuraciones de pfSense.

3.11 Eliminación de Medios de Almacenamiento

Todo disco duro o medio de almacenamiento de los nodos Proxmox que sea dado de baja debe ser destruido físicamente o borrado mediante métodos seguros que impidan la recuperación de datos.

3.12 Control de Acceso y Gestión de Identidades

Se implementará el acceso basado en roles (RBAC). El acceso remoto se realizará solo vía VPN con autenticación de doble factor.

3.13 Seguridad en la Relación con Proveedores

Los proveedores que den soporte a sistemas Oracle/SQLNet deben adherirse a estas políticas y firmar acuerdos de nivel de servicio (SLA) que incluyan cláusulas de seguridad.

3.14 Gestión de Incidentes de Seguridad

Los eventos detectados por Zabbix o reportados por usuarios serán categorizados y gestionados según su impacto operacional, documentando cada paso de la resolución.

3.15 Continuidad de Negocio y Recuperación ante Desastres

CLASIFICACIÓN: USO INTERNO | COPIA CONTROLADA *Documento propiedad de Pepito paga doble. Prohibida su reproducción total o parcial sin autorización.*

Se garantiza la disponibilidad de los servicios mediante réplicas de máquinas virtuales y un plan de recuperación probado anualmente usando las herramientas de Veritas NetBackup.

3.16 Cumplimiento Legal y Normativo

Pepito paga doble se compromete a cumplir con las leyes de protección de datos vigentes y los estándares de la norma ISO 27001:2022.

CLASIFICACIÓN: USO INTERNO | COPIA CONTROLADA *Documento propiedad de Pepito paga doble. Prohibida su reproducción total o parcial sin autorización.*